

CompTIA Security+

BILINGUAL STUDY SUITE (SY0-701)

PRACTICE EXAM QUIZ BANK

A curated bank of 10 scenario-based, highly realistic CompTIA Security+ questions written in official English, paired with comprehensive explanations in Portuguese.

Primary language of study: ENGLISH (Official Exam Standard)

Portuguese translation & annotation support included

Designed for candidates studying with Shelly & Gibson SY0-701 Study Guide
Created in 2026 | Safe & Comprehensive Preparation

QUESTION 1 of 10*Domain: 1.0 General Security Concepts*

A security manager is updating an organization's acceptable use policy (AUP) to restrict employees from plugging in personal USB storage devices on corporate workstations. This restriction is documented in the policy manual and is also communicated during annual training. Additionally, the IT department has configured an Active Directory Group Policy Object (GPO) that completely disables USB mass storage access on all endpoints. Which of the following pairs of security controls has been implemented?

- A. Managerial and Technical
- B. Operational and Physical
- C. Managerial and Operational
- D. Technical and Physical

CORRECT ANSWER: Option A**Gabarito Comentado (PT-BR):**

O controle foi implementado de duas maneiras:

1. ****Managerial (Administrativo/Gerencial)**:** A restrição foi documentada na política (AUP) e ensinada no treinamento anual. Políticas, diretrizes e treinamentos são controles gerenciais.
2. ****Technical (Técnico)**:** A restrição foi imposta eletronicamente nos endpoints usando uma diretiva do Active Directory (GPO) que bloqueia o hardware. Bloqueio de portas de hardware por software de gerenciamento é um controle técnico.

Por que as outras alternativas estão incorretas?

- B está incorreta pois não há controles físicos (como travas de porta USB físicas ou trancas) ou operacionais envolvidos no bloqueio direto.
- C está incorreta porque o bloqueio via GPO não é um controle operacional (processos executados por pessoas), mas sim técnico.
- D está incorreta porque não há controle físico envolvido nesta ação específica.

Golden Exam Rule (EN):

Policies and training represent Managerial controls, while configurations enforced by operating systems or software represent Technical controls.

QUESTION 2 of 10

Domain: 1.0 General Security Concepts

An enterprise wants to deploy an authentication mechanism that completely mitigates credential-harvesting attacks (such as credential stuffing and phishing) and eliminates the reliance on traditional passwords. Which of the following solutions should the security team implement to achieve this goal?

- A. Multifactor Authentication (MFA) utilizing SMS-based shortcodes
- B. Passwordless authentication using FIDO2/WebAuthn-compliant hardware security keys
- C. Single Sign-On (SSO) integrated with an LDAP database and complex passwords
- D. Federated authentication utilizing SAML 2.0 and time-based one-time passwords (TOTP)

CORRECT ANSWER: Option B**Gabarito Comentado (PT-BR):**

A resposta correta é a **B**. A autenticação sem senha (passwordless) que utiliza o padrão FIDO2/WebAuthn elimina completamente a senha tradicional e é imune a ataques de phishing de credenciais. O FIDO2 associa o login a um par de chaves criptográficas geradas no hardware físico do usuário, garantindo que o usuário só consiga logar se possuir o token físico e se o domínio da web bater com o registrado no par de chaves (mitigando phishings onde o site parece real mas tem domínio diferente).

Por que as outras alternativas estão incorretas?

- A está incorreta porque SMS MFA ainda depende de uma senha inicial e é vulnerável a ataques de interceptação (como SIM Swapping) e phishings sofisticados (MFA fatigue/reverse proxies).
- C está incorreta porque o LDAP com senhas complexas ainda depende de senhas tradicionais, as quais podem ser roubadas via phishing ou vazamento de banco de dados.
- D está incorreta porque, embora a federação via SAML e TOTP seja segura, o TOTP tradicional pode ser inserido em proxies reversos de phishing e a autenticação inicial ainda depende de uma credencial tradicional (senha) para a maior parte dos IdPs clássicos.

Golden Exam Rule (EN):

FIDO2/WebAuthn passwordless authentication represents the gold standard for phishing-resistant MFA because cryptographic assertions are bound to the specific web origin domain.

QUESTION 3 of 10

Domain: 2.0 Threats, Vulnerabilities, and Mitigations

A financial company's e-commerce application has recently experienced a major breach. Attackers were able to inject arbitrary SQL code into the login field, bypass authentication entirely, and dump database tables. Security engineers reviewed the logs and noticed that input containing characters like `` OR '1'='1` was executed directly by the backend database. To prevent this vulnerability from being exploited in the future, which of the following is the MOST secure coding practice to implement?

- A. Implement robust client-side input validation using JavaScript regex patterns.
- B. Use parameterized queries (Prepared Statements) for all database interactions.
- C. Sanitize and encode all outputs using HTML entity encoding.
- D. Deploy a Web Application Firewall (WAF) in front of the application server.

CORRECT ANSWER: Option B

Gabarito Comentado (PT-BR):

A resposta correta é a ****B****. O uso de consultas parametrizadas (Prepared Statements) é o método definitivo e mais seguro para mitigar o SQL Injection (SQLi). Ele força o interpretador do banco de dados a tratar qualquer entrada do usuário estritamente como um parâmetro (dado), e nunca como código executável, neutralizando qualquer caractere de controle injetado como `` OR '1'='1`.

Por que as outras alternativas estão incorretas?

- A está incorreta porque a validação no lado do cliente (Client-side) é usabilidade e não segurança; um atacante pode facilmente interceptar a requisição e ignorar o JavaScript enviando o payload diretamente para a API via curl ou Postman.
- C está incorreta porque a codificação de saída (HTML Encoding) previne ataques de Cross-Site Scripting (XSS), mas não protege contra injeções que ocorrem no banco de dados backend (SQLi).
- D está incorreta porque colocar um WAF é um controle compensatório ou de borda, e não uma prática de desenvolvimento/código seguro. A pergunta pede explicitamente pela 'MOST secure coding practice' (prática de programação mais segura).

Golden Exam Rule (EN):

Prepared statements (parameterized queries) prevent SQL injection at the source by separating executable code from user-supplied data.

QUESTION 4 of 10

Domain: 3.0 Security Architecture

An enterprise is planning to transition its on-premises infrastructure to a hybrid cloud environment. The security architect wants to ensure that all corporate security policies, data loss prevention (DLP) rules, and access control policies are consistently applied when employees access cloud resources (such as Salesforce, Microsoft 365, and AWS management consoles) from both inside the corporate network and remote locations. Which of the following solutions is BEST suited for this requirement?

- A. Cloud Access Security Broker (CASB)
- B. Infrastructure as Code (IaC) configuration templates
- C. Next-Generation Firewall (NGFW) deployed at the head office
- D. Virtual Private Network (VPN) Gateway with full-tunnel routing

CORRECT ANSWER: Option A**Gabarito Comentado (PT-BR):**

A resposta correta é a ****A****. Um CASB (Cloud Access Security Broker) atua como um intermediário de segurança entre os usuários corporativos e os serviços em nuvem (SaaS, PaaS, IaaS). Ele é especificamente projetado para estender políticas de DLP corporativas, monitorar Shadow IT, aplicar criptografia, aplicar políticas de acesso baseadas em contexto e garantir a conformidade em múltiplos ambientes de nuvem, independentemente de onde o tráfego do usuário venha.

Por que as outras alternativas estão incorretas?

- B está incorreta porque o IaC serve para automatizar o provisionamento de infraestrutura (como criar VMs na nuvem repetidamente), mas não monitora ou impõe políticas de acesso/DLP em tempo real durante o uso das aplicações SaaS por funcionários.
- C está incorreta porque um NGFW de sede física não consegue ver ou proteger o tráfego de um funcionário que está trabalhando em casa (home office) e acessando diretamente o Microsoft 365 de sua banda larga residencial, a menos que ele passe pela VPN corporativa.
- D está incorreta porque a VPN com túnel completo direciona o tráfego para a sede e cria gargalos de rede severos, além de não possuir as capacidades avançadas integradas de monitoramento DLP nativas e visibilidade Shadow IT que o CASB oferece.

Golden Exam Rule (EN):

Use a CASB when you need to enforce enterprise security policies, visibility, and data loss prevention rules consistently across multi-cloud and SaaS environments.

QUESTION 5 of 10

Domain: 4.0 Security Operations

A system administrator is reviewing network access logs and notices a sudden increase in failed authentication attempts targeting several administrative accounts on a Sunday night. Immediately after, an alert from the Host Intrusion Detection System (HIDS) is triggered on a database server, indicating an unauthorized privilege escalation attempt. According to the standard Incident Response Process, what should the security team perform NEXT?

- A. Analyze log files from the Active Directory server to identify the source IP address.
- B. Isolate the compromised database server from the network to prevent lateral movement.
- C. Restore the database server to its last clean snapshot from a backup.
- D. Create a detailed Incident Report and conduct a 'Lessons Learned' meeting with executive management.

CORRECT ANSWER: Option B

Gabarito Comentado (PT-BR):

A resposta correta é a ****B****. De acordo com o processo tradicional de Resposta a Incidentes (PICERL: Preparação, Identificação, Contenção, Erradicação, Recuperação, Lições Aprendidas), após identificar que há uma intrusão ativa com escalção de privilégios em andamento (fase de Identificação concluída), o próximo passo crítico imediato é a ****Contenção (Containment)****. Isolar o servidor de banco de dados afetado da rede impede que o atacante se mova lateralmente para outros servidores ou exfiltre dados confidenciais.

Por que as outras alternativas estão incorretas?

- A está incorreta porque, embora a investigação de logs seja importante, ela faz parte da Identificação. Quando um comprometimento ativo e grave no banco de dados é confirmado, conter o dano tem prioridade absoluta antes de continuar investigando de onde vem o IP.
- C está incorreta porque a restauração a partir do backup limpo faz parte da fase de ****Recuperação (Recovery)****. Você nunca deve recuperar ou reiniciar um servidor até que o incidente tenha sido contido e o atacante/vulnerabilidade tenha sido erradicado (fase de Erradicação), sob o risco de restaurar o sistema e ele ser imediatamente reinfestado ou do atacante usar as credenciais comprometidas que continuam válidas.
- D está incorreta porque o relatório e a reunião de Lições Aprendidas representam a última etapa do processo de resposta (Lessons Learned), ocorrendo dias ou semanas após o incidente ter sido resolvido por completo.

Golden Exam Rule (EN):

Containment is the highest priority immediate action once a security compromise has been identified, to isolate the threat and prevent further damage.

QUESTION 6 of 10

Domain: 5.0 Security Program Management and Oversight

A multinational corporation is designing its Disaster Recovery Plan (DRP) and wants to establish specific metrics for its core financial transaction system. Executive management has stated that in the event of an outage, the system must be restored to operations within 4 hours. Additionally, to avoid catastrophic financial impacts, no more than 15 minutes of transactional data can be lost. Which of the following metrics should the database engineering team design their replication and backups to meet?

- A. RTO of 15 minutes and RPO of 4 hours
- B. MTBF of 4 hours and MTTR of 15 minutes
- C. RTO of 4 hours and RPO of 15 minutes
- D. MTTR of 4 hours and MTBF of 15 minutes

CORRECT ANSWER: Option C

Gabarito Comentado (PT-BR):

A resposta correta é a ****C****.

- ****RTO (Recovery Time Objective)****: É o objetivo de tempo máximo tolerado para restaurar o sistema de volta ao ar após uma queda. A gestão especificou 4 horas, logo, RTO = 4 horas.

- ****RPO (Recovery Point Objective)****: É a quantidade máxima de perda de dados aceitável medida em tempo. A gestão especificou que não aceita perder mais do que 15 minutos de dados transacionais, logo, o RPO = 15 minutos. Isso exige que o banco de dados replique os dados quase em tempo real ou tire backups a cada 15 minutos.

Por que as outras alternativas estão incorretas?

- A inverteu os termos (RTO e RPO estão trocados).

- B e D utilizam métricas incorretas para este caso. MTBF (Mean Time Between Failures) indica a confiabilidade/tempo médio entre falhas e MTTR (Mean Time to Repair) indica o tempo médio de reparo, mas não são as métricas de conformidade empresarial de planejamento de desastres exigidas de forma pontual pela pergunta.

Golden Exam Rule (EN):

RTO is the target time to restore systems back online; RPO is the maximum allowable age of data that can be lost from backup storage.

QUESTION 7 of 10

Domain: 2.0 Threats, Vulnerabilities, and Mitigations

During a proactive threat hunting exercise, a security analyst discovers a series of unrecognized, scheduled system tasks running on several key workstations. Further analysis reveals these tasks are executing a hidden utility that captures keyboard inputs, packages them into text files, and sends them over an encrypted tunnel to an external IP address belonging to a known dynamic DNS provider. Which of the following types of malware has MOST likely compromised these workstations?

- A. Logic Bomb
- B. Remote Access Trojan (RAT)
- C. Keylogger
- D. Spyware

CORRECT ANSWER: Option B

Gabarito Comentado (PT-BR):

A resposta correta é a ****B****. Embora o utilitário capture teclas digitadas (função de um keylogger), a descrição descreve um pacote completo de malware persistente instalado no sistema via tarefas agendadas, que mantém uma conexão ativa de controle de canal e exfiltra dados por um túnel criptografado para um servidor de comando e controle (C2) controlado pelo atacante. Isso caracteriza um ****RAT (Remote Access Trojan)****.

Por que as outras alternativas estão incorretas?

- A está incorreta porque uma Logic Bomb aguarda pacientemente por um gatilho de tempo ou evento (ex: demissão de um programador) para executar código destrutivo, o que não reflete a coleta constante e túnel criptografado ativo.
- C está incorreta porque o 'keylogger' puro é a funcionalidade específica de software que apenas grava as teclas digitadas, enquanto a questão descreve um cavalo de troia completo que instalou utilitários de sistema e mantém controle persistente remoto de rede (C2).
- D está incorreta porque 'Spyware' é uma categoria geral de malware de rastreamento de dados do usuário (cookies, telas), mas um Trojan de controle remoto (RAT) é a definição técnica mais precisa para uma ameaça persistente ativa que controla o endpoint e se comunica de volta por portas ocultas.

Golden Exam Rule (EN):

RATs (Remote Access Trojans) provide attackers with persistent, interactive, unauthorized control over compromised endpoints, often masquerading as benign files.

QUESTION 8 of 10

Domain: 3.0 Security Architecture

A network security administrator is configuring a new corporate wireless network. The administrator wants to implement the highest available security standard to protect against offline dictionary attacks, protect the initial connection handshake from being cracked, and ensure forward secrecy for all users. Which of the following wireless configurations should the administrator select?

- A. WPA2 Enterprise utilizing EAP-TLS
- B. WPA2 Personal using a strong Pre-Shared Key (PSK)
- C. WPA3 Personal using Simultaneous Authentication of Equals (SAE)
- D. WPA3 Enterprise utilizing 128-bit WEP-compatible mode

CORRECT ANSWER: Option C**Gabarito Comentado (PT-BR):**

A resposta correta é a ****C****. O padrão ****WPA3 Personal**** resolve a grande fraqueza do WPA2 ao substituir a chave pré-compartilhada (PSK) clássica pelo método ****SAE (Simultaneous Authentication of Equals)****. O SAE utiliza trocas de chaves Diffie-Hellman criptográficas para o handshake inicial. Isso torna o handshake totalmente imune a ataques de dicionário offline e interceptações de tráfego passivas. Se um hacker capturar o handshake do ar, ele não conseguirá forçar a senha offline, e o tráfego interceptado continuará protegido graças ao Forward Secrecy.

Por que as outras alternativas estão incorretas?

- A está incorreta porque, embora o WPA2 Enterprise com certificados digitais (EAP-TLS) seja extremamente seguro, a questão foca na proteção de offline dictionary attacks no handshake geral sem a necessidade de implantar uma infraestrutura completa de certificados e servidores RADIUS corporativos típicos de enterprise (o SAE fornece isso de forma autônoma para chaves compartilhadas/pessoais).
- B está incorreta porque o PSK tradicional do WPA2 é altamente vulnerável a ataques de dicionário offline caso o handshake de 4 etapas (4-way handshake) seja capturado do ar.
- D está incorreta porque o WEP é um protocolo extremamente fraco e obsoleto (quebrado em minutos); nenhum modo compatível com WEP deve ser habilitado e o WPA3 Enterprise real foca em criptografia de 192 bits e não em WEP de 128 bits.

Golden Exam Rule (EN):

WPA3 replaces the vulnerable WPA2 4-way handshake with Simultaneous Authentication of Equals (SAE), completely preventing offline password cracking attempts.

QUESTION 9 of 10*Domain: 1.0 General Security Concepts*

An IT administrator has generated a public and private key pair on a new server. The administrator needs to send sensitive backups to an offsite cloud storage bucket and wants to ensure that the backup files are encrypted locally before transmission. Additionally, the cloud bucket must be able to verify that the files came from this specific server and were not modified during transit. Which of the following combinations of cryptographic keys should be utilized to perform these actions?

- A. Encrypt files with the server's private key; verify with the server's public key.
- B. Encrypt files with a symmetric shared key; sign the files using the server's private key.
- C. Encrypt files with the cloud storage's private key; sign using the server's public key.
- D. Encrypt files using the server's public key; verify using the cloud storage's private key.

CORRECT ANSWER: Option B**Gabarito Comentado (PT-BR):**

A resposta correta é a ****B****. Para enviar grandes volumes de backups de forma segura e eficiente, o processo técnico correto combina:

1. ****Symmetric shared key (Criptografia Simétrica)****: Utilizada para criptografar os dados do backup rapidamente em nível local (por exemplo, usando AES), pois a criptografia assimétrica de arquivos gigantes seria extremamente lenta e consumiria muita CPU.
2. ****Sign with server's private key (Assinatura Digital)****: O servidor assina digitalmente o hash do backup usando sua própria chave privada. O receptor (nuvem) utiliza a chave pública do servidor para descriptografar a assinatura e comparar os hashes. Isso garante a ****integridade**** (não houve modificações em trânsito) e a ****autenticação**** (veio especificamente daquele servidor).

Por que as outras alternativas estão incorretas?

- A está incorreta porque você ****nunca**** criptografa dados sensíveis com a chave privada. Se você criptografar algo com sua chave privada, qualquer pessoa no mundo com sua chave pública poderá descriptografar o arquivo, violando a confidencialidade por completo. Chave privada assina (comprova autoria), chave pública criptografa (segredo).
- C e D estão incorretas porque os pares de chaves estão invertidos ou usam lógica inviável para segurança e performance.

Golden Exam Rule (EN):

Symmetric encryption is used for data bulk encryption due to performance, while asymmetric private keys are used to generate digital signatures ensuring authentication and non-repudiation.

QUESTION 10 of 10*Domain: 4.0 Security Operations*

A security analyst is examining an alert from the Security Information and Event Management (SIEM) system indicating that a compromised external host has successfully performed a zone transfer query against the company's external DNS server. Which of the following DNS records was the attacker MOST likely trying to harvest, and what tool could be used by the analyst to inspect the DNS configuration?

- A. MX records to identify mail servers; inspected using the ``ping`` command
- B. AXFR records to download the entire zone database; inspected using the ``dig`` command
- C. A records to map hostnames to IP addresses; inspected using the ``netstat`` command
- D. TXT records to view SPF and DKIM tags; inspected using the ``ipconfig`` command

CORRECT ANSWER: Option B**Gabarito Comentado (PT-BR):**

A resposta correta é a ****B****. Uma consulta de transferência de zona DNS usa o comando/registro especial ****AXFR**** para solicitar a cópia completa do banco de dados de zonas daquele servidor DNS. Se for bem-sucedido, o invasor obtém uma lista completa de todos os subdomínios, IPs internos mapeados e servidores configurados pela empresa, facilitando consideravelmente a fase de reconhecimento. A ferramenta padrão de terminal utilizada em sistemas Linux/Unix para inspecionar registros de DNS e testar transferências de zona é o comando ``dig`` (ex: ``dig axfr @ns1.empresa.com``).

Por que as outras alternativas estão incorretas?

- A está incorreta porque o comando ``ping`` apenas testa a conectividade enviando pacotes ICMP Echo Request, ele não é uma ferramenta de consulta DNS detalhada.
- C está incorreta porque o ``netstat`` serve para visualizar portas e conexões de rede ativas na máquina local, não servindo para consultar registros DNS externos.
- D está incorreta porque ``ipconfig`` (Windows) ou ``ifconfig`` (Linux) são usados apenas para verificar e configurar as interfaces de rede locais da própria máquina, e não para interagir com servidores DNS remotos.

Golden Exam Rule (EN):

DNS zone transfers utilize the AXFR request format; security teams should disable external AXFR queries and use the ``dig`` utility for verification.